

DDoS Incident Analysis

Simulated portfolio investigation: triage, evidence, severity, containment, recovery, and lessons learned

Incident Summary

Scenario: A simulated customer-facing web service experienced a sharp increase in inbound traffic that exhausted application capacity and caused intermittent availability. The evidence below is synthetic and created to demonstrate incident-response methodology.

Field	Assessment
Incident ID	IR-2026-001
Classification	Availability / Denial of Service
Severity	SEV-2 / High
Start time	2026-08-18 14:05 ET
Detection source	Availability monitor + firewall traffic spike
Affected asset	Public e-commerce web tier
Customer impact	Intermittent timeouts and failed page loads
Data compromise	No evidence of confidentiality or integrity impact
Status	Contained and recovered

Severity Rationale

- Business impact was high because the public service became intermittently unavailable.
- Scope was limited to the internet-facing service tier; no internal lateral movement was identified.
- No evidence indicated data access, modification, or account compromise.
- Service recovered after filtering, rate controls, and capacity stabilization.

Synthetic Evidence & Indicators

Evidence ID	Source	Observation	Analyst interpretation	Disposition
E-001	Availability monitor	5xx errors increased from baseline to sustained elevated levels.	Confirms service impact during traffic surge.	Retained for timeline
E-002	Firewall	Inbound connection volume rose sharply from numerous external sources.	Pattern consistent with volumetric or distributed request flooding.	Used for scope
E-003	Web logs	Repeated requests targeted the same public endpoints at abnormal frequency.	Supports application-layer resource exhaustion.	Rate-limit targeted paths
E-004	Infrastructure metrics	CPU and connection queues saturated during peak traffic.	Confirms resource exhaustion rather than application code failure.	Scale + filter
E-005	Post-containment metrics	Error rate and connection pressure returned toward baseline.	Supports successful containment and recovery.	Closure evidence

Incident Timeline

Time	Event / Analyst Action
14:05	Availability monitor detected elevated latency and HTTP 5xx responses.
14:08	SOC/operations correlated outage symptoms with firewall traffic growth.
14:12	Incident classified as suspected DDoS; SEV-2 declared due to customer impact.
14:18	Traffic patterns reviewed by source, destination, URI, request frequency, and connection behavior.
14:25	Rate limiting and filtering applied to abusive patterns; upstream mitigation engaged in the simulated scenario.
14:33	Application capacity stabilized; error rate began declining.
14:47	Service availability returned to normal operating range.
15:05	Monitoring confirmed sustained recovery; incident moved to post-incident review.

MITRE ATT&CK; Mapping

- **Impact tactic:** Network Denial of Service / Endpoint Denial of Service concepts are relevant to availability-focused adversary behavior. The case is mapped at the behavior level rather than asserting a specific threat actor.
- ATT&CK; mapping is used to describe observed behavior, not to prove attribution.

Containment, Recovery & Corrective Actions

- Apply rate controls, upstream filtering, WAF/CDN protections, and connection thresholds appropriate to the service.
- Increase observability for traffic rate, source concentration, URI anomalies, connection queues, latency, and 5xx error rates.
- Document escalation criteria for availability incidents and confirm provider contacts before an event.
- Perform capacity testing and define thresholds for automated scaling or mitigation.
- Retain a post-incident timeline, decision log, metrics, and lessons learned.